

Cursul 11

Elemente de securitate

Utilizarea Sistemelor de Operare (USO)

11 decembrie 2017

Departamentul de Calculatoare

Moto

The only truly secure system is one that is powered off, cast in a block of concrete and sealed in a lead-lined room with armed guards - and even then I have my doubts.

Eugene H. Spafford

shell scripts

one liners

filtre de text

operatorul | (pipe)

cat, tac, rev, head, tail, nl

cut, tr, grep, sort, uniq

paste, join, fmt, column

sed, awk

comenzi parametrizate

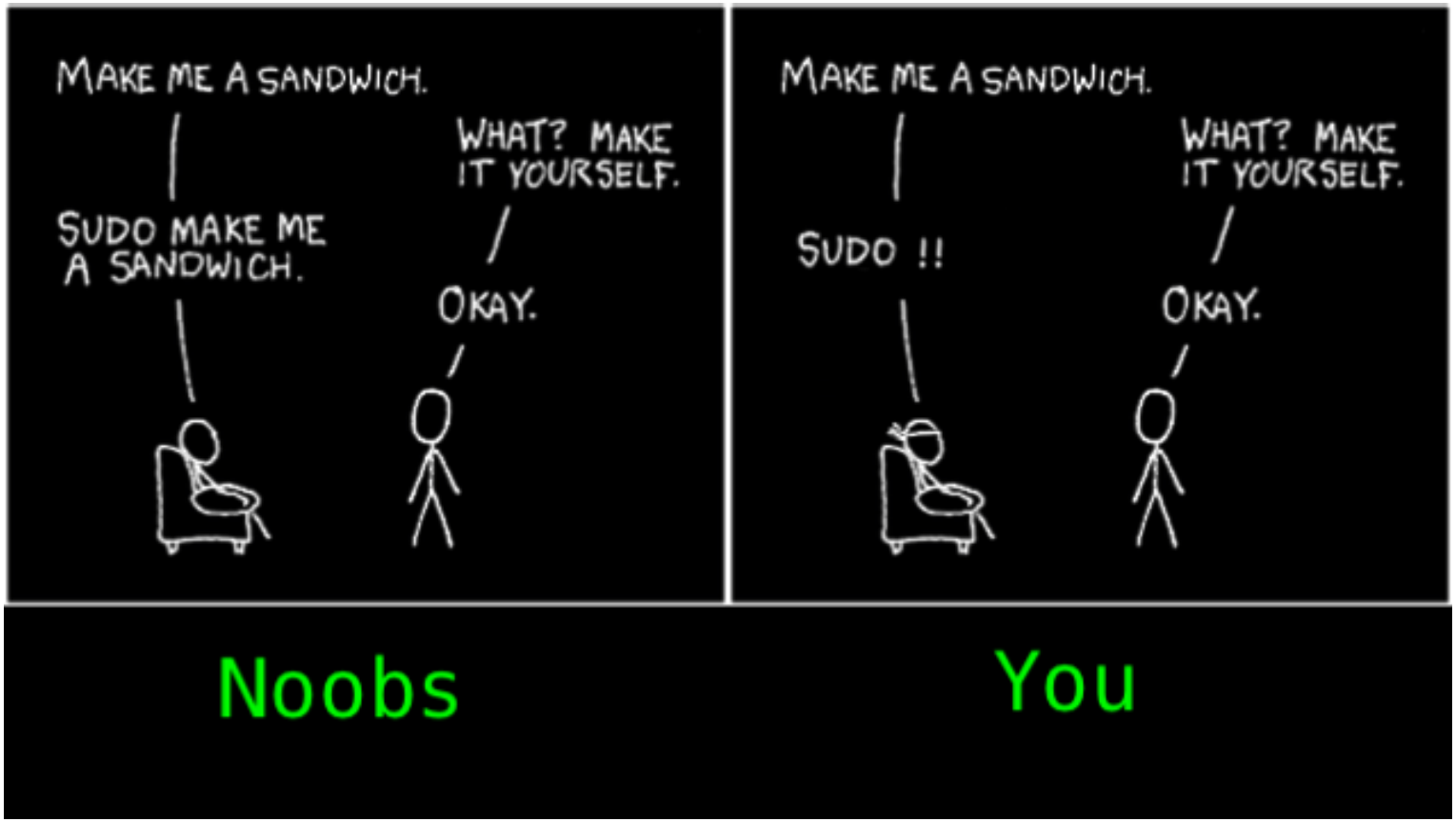
expandare: $(...)

zip, tar

file, stat

touch, mkdir, rm, cp, mv

gcc, apt-get install



http://fynnexp.com/13249-funny-cmd-scripts.html

- Suport (Introducere în sisteme de operare)
  - Capitolul 10 – Elemente de securitate

În această săptămână la USO

- laboratorul 11 (,,Considerente hardware") are loc în această săptămână
- tema 4 (suplimentară) va fi anunțată în această săptămână
  - întrebați, întrebați, întrebați
  - folosiți forumul
  - ajutați colegii pe forum
  - `https://ocw.cs.pub.ro/courses/uso/regulament`
    - secțiunea ,,Recomandări de comunicare electronică"
    - secțiunea ,,Realizarea temelor"
- slide-urile cursului 12: ,,Considerente Hardware" vor fi publicate după 3 ianuarie 2018
- Quest-ul final WoUSO începe sâmbătă, 16 decembrie 2017
  - mașină virtuală
  - 33 de niveluri hands-on
- Vacanță plăcută!

Câteva întâmplări

- 6.46 million LinkedIn passwords leaked online (June 2012)
  - `http://www.zdnet.com/article/6-46-million-linkedin-passwords-leaked-online/`
- $12,000 computer (Project Erebus v2.5), 8 AMD Radeon HD7970 GPU cards (August 2012)
  - are nevoie de 12 ore pentru a folosi *brute force* pe întreg spațiul de parole de 8 caractere printabile
  - `http://arstechnica.com/security/2012/08/passwords-under-assault/`
- NSA infiltrates links to Yahoo, Google data centers worldwide, Snowden documents say (October 2013)
  - `http://www.washingtonpost.com/world/national-security/nsa-infiltrates-links-to-yahoo-google-data-centers-worldwide-snowden-documents-say/2013/10/30/e51d661e-4166-11e3-8b74-d89d714ca4dd_story.html`
- The Heartbleed Bug (April 2014)
  - vulnerabilitate în biblioteca OpenSSL, cea mai răspândită pentru comunicare criptate
  - `http://heartbleed.com/`
- Celebrity photo leak (September 2014)
  - ,,Security researcher reported brute force attacks were possible in March.''
  - `http://arstechnica.com/security/2014/09/apple-knew-of-icloud-api-weakness-months-before-celeb-photo-leak-broke/`

Și alte întâmplări

- Los Angeles Hospital Hit (February 2016)
  - răscumpărare plătită pentru recuperarea conturilor de email și a informațiilor pacienților
  - `https://www.theguardian.com/technology/2016/feb/17/los-angeles-hospital-hacked-ransom-bitcoin-hollywood-presbyterian-medical-center`
- IRS Security Breach (February 2016)
  - accesarea datelor personale a peste 700 000 de americani
  - `http://www.usatoday.com/story/money/2016/02/26/cyber-hack-gained-access-more-than-700000-irs-accounts/80992822/`
- Mossack Fonseca Leak (May 2016)
  - publicarea a 2.6 TB de documente private
  - `http://www.bbc.com/news/world-latin-america-36232142`
- Banner Health (August 2016)
  - pierderea datelor personale a 3.7 milioane de pacienți
  - `http://www.securityweek.com/37-million-exposed-banner-health-breach`
- Bitfinex Heist (August 2016)
  - furtul a echivalentului de 72 milioane USD
  - `http://www.reuters.com/article/us-bitfinex-hacked-hongkong-idUSKCN10E0KP`
- suma medie cererilor de răscumpărare: 679$ (față de 342$ în 2015)

- protecția informațiilor prețioase (companii, instituții) sau private (persoane)
- Ce este un sistem sigur?
  - resursele sale sunt utilizate și accesate în orice împrejurare așa cum se dorește
- Se poate obține un sistem sigur?
  - Da. Complet izolat de lumea exterioară.
  - nu este util, nici flexibil
- Ce înseamnă securizarea unui sistem de calcul?
  - folosirea de metode de protecție **suficient** de puternice
  - un potențial atacator va fi **descurajat**
  - compromiterea sistemului este **greu** de realizat
- Securitatea este un proces nu o finalitate

Cerințele pentru securitate (IT)

- *IT security*, *information security*
- confidențialitate
- protejarea resurselor
- auditiarea activităților (monitorizare)
- integritate
- autenticitate
- disponibilitate
- rulare conform așteptărilor/standardelor (*compliance*)
- minimizarea riscurilor

- agenții sunt entitățile active într-un sistem: persoane, procese, departamente
- obiectele sunt resursele
- agenții au roluri, fiecare rol are anumite privilegii
- funcție de roluri, un agent poate executa anumite acțiuni și poate avea anumite forme de acces la obiecte

Principii în securitate

- principiul celui mai mic privilegiu (*least privilege*)
- principiul separării privilegiilor (*privilege separation*)
- *security through obscurity* vs. *security by design*
- cea mai slabă verigă
- simplitate (*feature creep*)
  - Bruce Schneier: *Complexity is the worst enemy of security.*
- *defense in depth*
- securitate vs. utilizabilitate

- la nivel de persoană
  - utilizatorii sunt aleși cu grijă
  - educarea utilizatorilor
- la nivel fizic
  - protecția încăperilor ce conțin sistemele de calcul
- la nivelul sistemului de operare
  - securizarea accesului (parole)
  - protecția resurselor SO (memorie, fișiere)
- la nivelul aplicației
  - autentificarea în cadrul aplicației
  - stabilirea rolurilor
  - criptarea datelor
  - politici de acces la resursele aplicației
- la nivelul rețelei
  - securizarea accesului de la distanță
  - filtrarea pachetelor de compromitere a rețelei

Resurse utile pentru securitate aplicată

- OWASP (*Open Web Application Security Project*): `https://www.owasp.org/index.php/Main_Page`
- wargames and challenge sites
  - `http://www.wechall.net/`
  - `http://overthewire.org/wargames/`
  - `http://captf.com/practice-ctf/`
  - `https://w3challs.com/`
- CTF (*Capture the Flag*) security contests
  - `https://ctftime.org/`
- Stack Exchange
  - `http://security.stackexchange.com/`
  - `http://crypto.stackexchange.com/`
  - `http://reverseengineering.stackexchange.com/`

- sistem de operare sigur: resursele acestuia sunt accesate în mod valid
- securitatea memoriei și a aplicațiilor
  - fiecare proces este izolat, nu poate scrie în memoria altui proces
  - fluxul de lucru al aplicației nu este deturnat
- securitatea accesului
  - gestiunea parolelor
  - privilegii pentru utilizatori
  - autentificare, autorizare, controlul accesului
  - limitări: câte accese simultane, câte procese pornite, cât spațiu pe disc ocupat
- securitatea sistemului de fișiere
  - permisiuni de acces la fișiere
  - izolarea accesului doar la anumite părți din sistemul de fișiere

- aspecte importante
  - directorul home al fiecărui utilizator
    - drepturi depline
    - utilizatorul poate sau nu permite accesul altor utilizator
  - doar utilizatorul privilegiat are acces la anumite intrări
    - fișiere de configurare, programe executabile
- Cum se implementează securitatea fișierelor?
  - permisiuni de acces (sau liste de acces)
    - pentru fiecare intrare se precizează drepturile utilizatorilor
    - formă redusă pe Unix (user, group, others)

- restricția drepturilor de creare a intrărilor în sistemul de fișiere
- valori tipice pentru `umask`: 022, 027, 077
- drepturi de creare implicite
  - 666 pentru fișier
  - 777 pentru director
- drepturi de creare efective
  - ȘI logic între permisiunile implicite și masca inversată

- autentificare
  - permiterea accesului unui utilizator (numit și agent sau subiect) la sistem
- Când este un utilizator autentic?
  - posedă o unitate de identificare (cheie, card)
  - posedă un nume de utilizator și o parolă
  - posedă un atribut de utilizator (amprentă, retină, semnătură)

Contul privilegiat

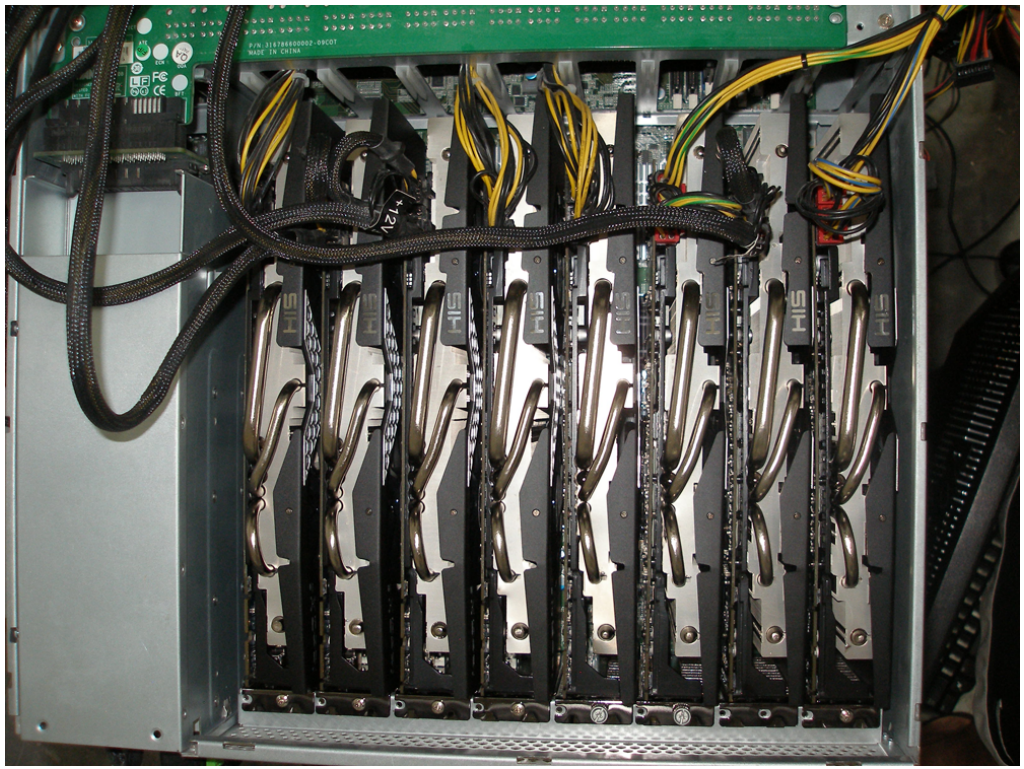
- controlul absolut al sistemului
  - obținerea contului de superuser înseamnă spargerea sistemului
- trebuie folosit **numai** atunci când este nevoie
  - pentru operații obișnuite, folosiți contul **neprivilegiat**
  - o bună parte din atacurile pe Windows se bazează pe faptul că utilizatorii folosesc numai contul `Administrator`
- `sudo`
  - permite unui utilizator obișnuit (dar de încredere) rularea unui set restrâns de comenzi cu privilegii de `root`
  - o formă de *privilege separation*

Autentificare, autorizare, controlul accesului

- autentificare (*authentication*)
  - permiterea utilizatorului în sistem pe baza credențialelor (parola, semnatură biometrică, certificat digital etc.)
- autorizare (*authorization*)
  - acordarea de drepturi de acces la resurse pentru utilizator
- controlul accesului (*access control*)
  - verificarea drepturilor de acces la resurse; se permite sau nu se permite accesul

- formă de autentificare (*username* + *password*)
  - se compară parola introdusă cu cea stocată de sistem
  - dacă cele două coincid se permite accesul
- modul `echo off` sau ,,cu steluțe”
  - împiedicarea *shoulder surfing*
- neajunsurile folosirii parolelor
  - păstrarea secretă a parolei
    - sticky-note care este lipit pe monitor
    - stocată în telefonul mobil
  - spargerea parolei
  - transferul parolei de la un utilizator autorizat la unul neautorizat

Password Cracking



http://arstechnica.com/security/2012/08/passwords-under-assault/

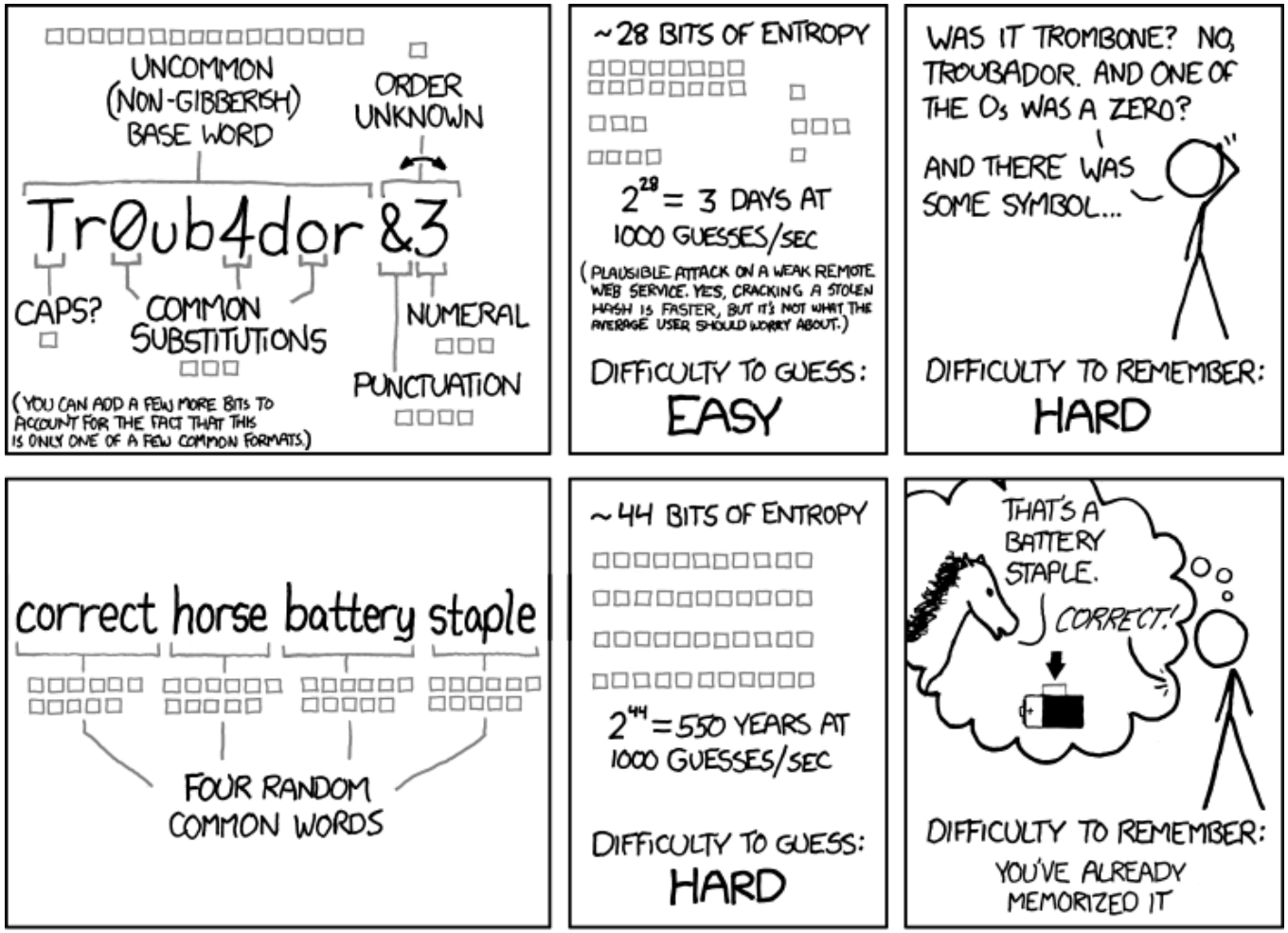
- Project Erebus v2.5
- AMD Radeon HD7970: 8.2 billion password combinations each second
- 8xAMD Radeon HD7970: 12 hours to brute force entire keyspace for any eight-character passwords (upper- or lower-case letter, digits or symbols)

Spargerea unei parole

- *guessing*
- *brute force*
- *dictionary attack*
- *hybrid attack*: dicționar și modificări uzuale (a devine 4 etc.)
- *social engineering*
- John the Ripper – `http://openwall.com/john/`
  - dicționare (*wordlist*)

- politică de alegere a parolelor
  - minim 10 caractere, atât lower case cât și upper case
  - cel puțin un caracter special sau numeric
  - nu trebuie să fie nume de persoane sau cuvinte din dicționar usor de reținut
- utilizarea parolelor generate aleator de sistem
  - `pwgen`
- verificarea periodică a parolelor utilizatorilor
- *password aging*: schimbarea parolei după o anumită perioadă
- folosirea de *passphrase*-uri: *stong bitter whiteboard mule*
- passphrase nepotrivit: *One does not simply walk into Mordor* – frază celebră, ușor de ghicit

Passwords vs. Passphrases



THROUGH 20 YEARS OF EFFORT, WE'VE SUCCESSFULLY TRAINED EVERYONE TO USE PASSWORDS THAT ARE HARD FOR HUMANS TO REMEMBER, BUT EASY FOR COMPUTERS TO GUESS.

http://xkcd.com/936/

- la început parolele se păstrau criptat în `/etc/passwd`
- fișierul `/etc/passwd` conține și alte informații
  - numele utilizatorilor
  - directorul home
  - shell-ul folosit
- multe programe au nevoie de informațiile de mai sus
  - fișierul `/etc/passwd` este citibil de toți utilizatorii

Drepturi de acces pe `/etc/passwd`

```
razvan@anaconda:~/junk$ ls -l /etc/passwd
-rw-r--r-- 1 root root 2147 Nov 4 15:35 /etc/passwd
```

- parola criptată este vizibilă
  - potențial risc de spargere prin încercări (*brute force*)

Parole în Unix (cont.)

- fișierul `/etc/shadow` – accesibil numai de root
- parola ar putea fi spartă prin încercări de login repetate
  - timeout între încercările de autentificare

/etc/passwd

```
razvan@anaconda:~/junk$ cat /etc/passwd | grep guest
guest:x:1001:1001:Guest,EF 303,,,Test:/home/guest:/bin/bash
```

/etc/shadow

```
razvan@anaconda:~/junk$ cat /etc/shadow | grep guest
cat: /etc/shadow: Permission denied
anaconda:/home/razvan/junk# cat /etc/shadow | grep guest
guest:$1$jv4hP2au$BSrUDS0J7LhJv8PrCFltU/:13124:0:99999:7:::
```

1. se introduce username-ul
2. se introduce parola
3. se localizează username-ul în sistem; dacă nu există, eroare
4. se aplică algoritmul de criptare peste parola introdusă
   - este un algoritm one-way: doar criptare, nu poate fi decriptat
   - pentru brute force, se generează parole și se criptează
5. se verifică șirul criptat obținut mai sus cu parola criptată din fișierul `/etc/shadow`
6. dacă cele două șiruri (criptate) corespund, utilizatorul este admis în sistem; altfel, eroare

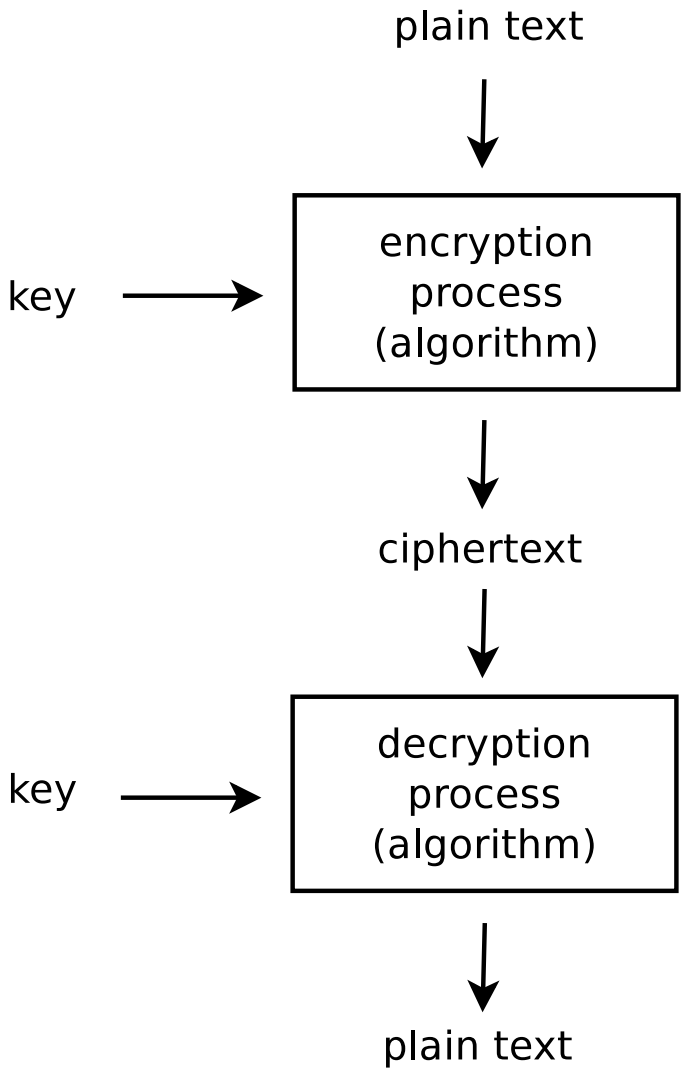
- biometrice (amprentă, retină)
- authentication tokens (precum cele folosită la online banking)
- *two-factor*: parolă + SMS, parola + token
- OAuth: folosirea contului de Google, Facebook, Twitter pe alte site-uri fără ca parola să fie transmisă

- studiul comunicării sigure
- criptare, hashing, criptanaliză
- utilizare: criptare (comunicare sigură), autentificare, semnături digitale

Criptare și decriptare

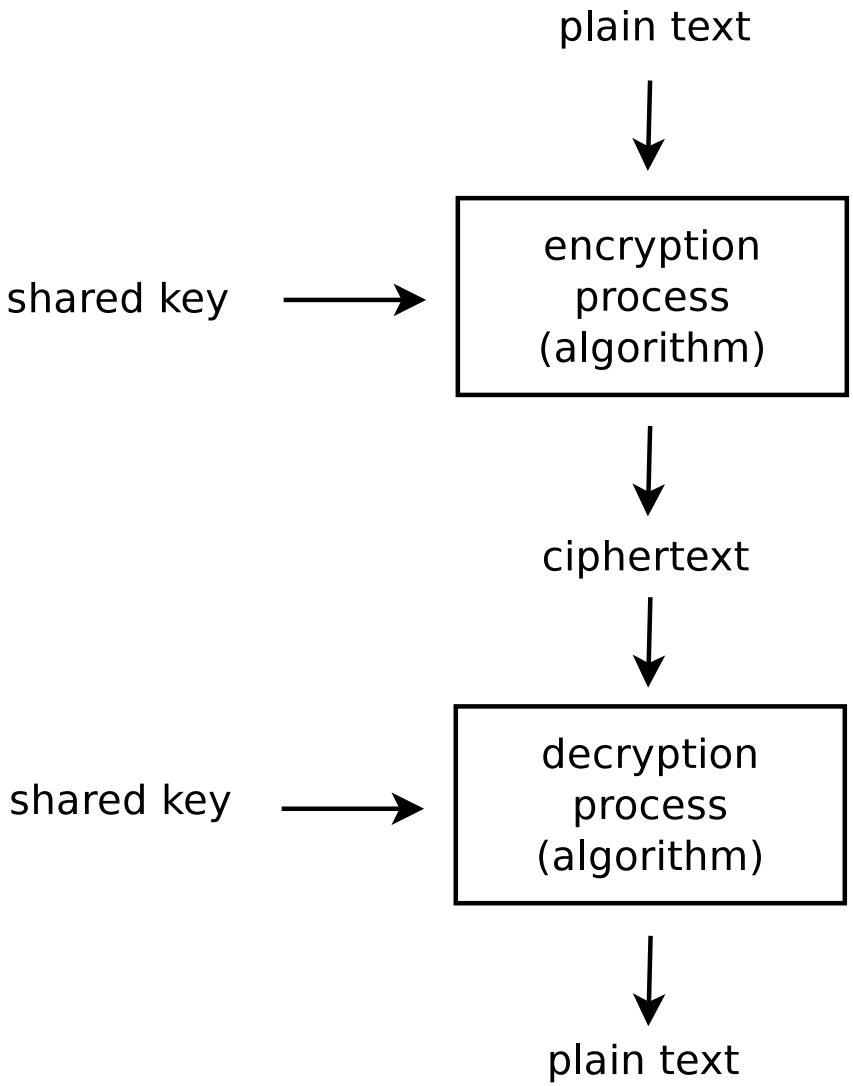
- criptarea este procesul de transformare a unui text clar (*plain text*) într-un text cifrat (*ciphertext*)
- decriptarea este procesul invers
- criptarea/decriptarea necesită
  - un algoritm
  - o cheie
  - date/mesaj
- Ce criptăm?
  - date de orice fel
  - trafic de rețea
  - sisteme de fișiere/partiții

Criptare și decriptare (2)



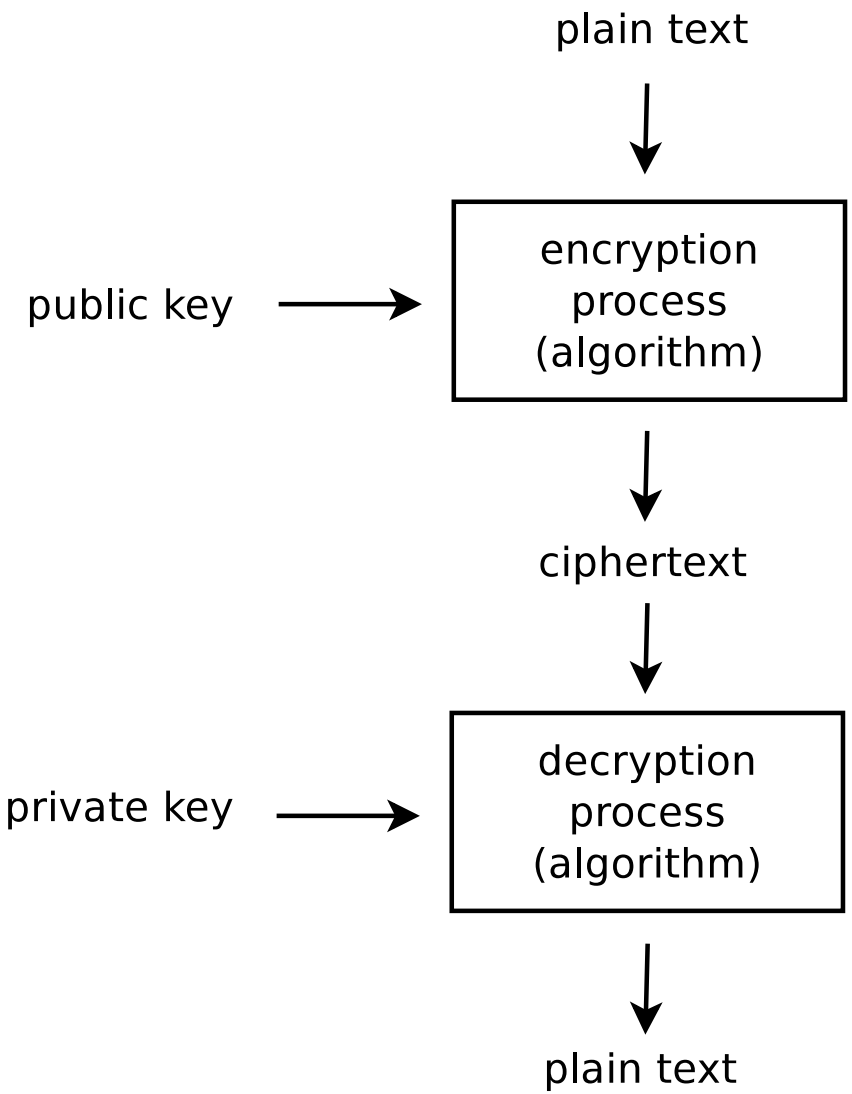
- *symmetric-key cryptography*
- transmițătorul și receptorul au aceeași cheie
- de avut în vedere unde se stochează cheia
- rapidă, implementare în hardware
- standardul de criptare cu chei simetrice este algoritmul AES (*Advanced Encryption Standard*)

Criptare și decriptare cu chei simetrice

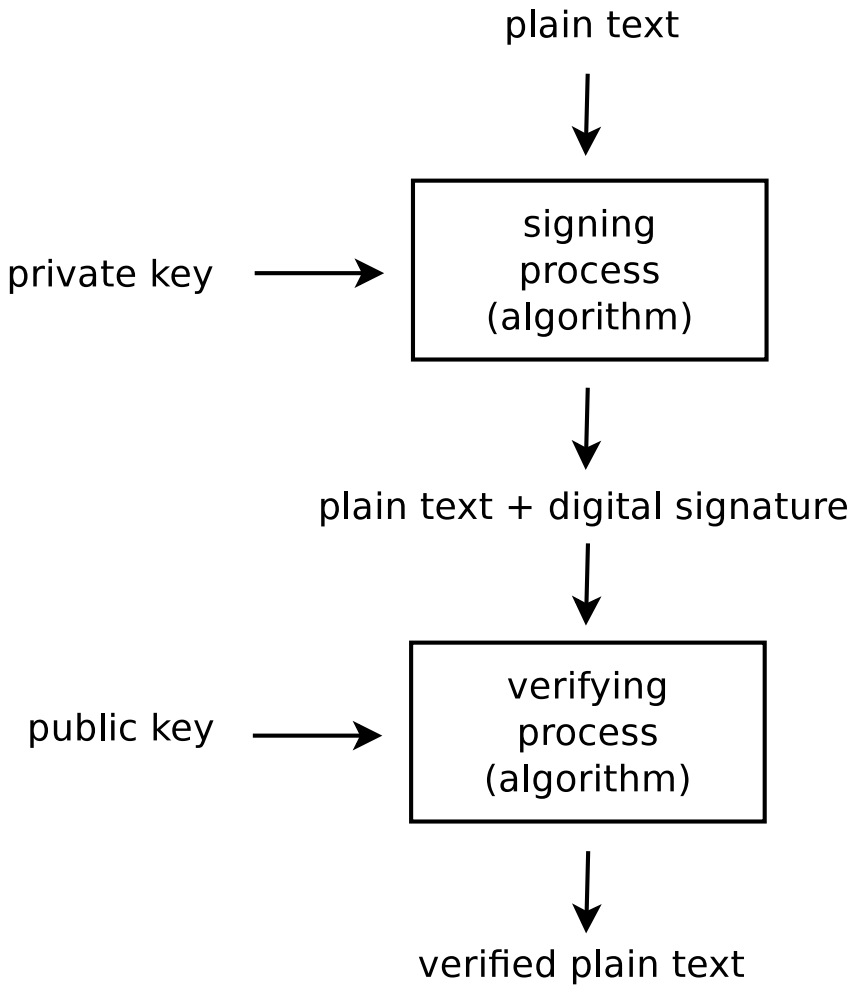


- *public-key cryptography*
- o cheie este privată (secretă) și altă cheie este publică
- cele două cheie sunt legate matematic
- criptare cu cheia publică (orice poate cripta); decriptare cu cheia privată (doar deținătorul poate decripta)
  - înceată
  - folosită doar în fazele de inițiere a unei conexiuni pentru stabilirea unei chei simetrice
  - folosită pentru autentificare: cine are cheia privată poate decripta mesajul și garanta că este utilizatorul în cauză
- semnături digitale
  - mesajul este trimis în clar dar are atașat o semnătură digitală
  - doar cheia privată poate semna (doar deținătorul)
  - cheia publică poate verifia semnătura (oricine)
- RSA, curbe eliptice

Criptare și decriptare cu chei publice



Semnare și verificare cu chei publice



- Ross Anderson
- 2nd Edition, 2010
- prima ediție poate fi descărcată gratis
- o privire în ansamblu a securității sistemelor și rețelelor
- atacuri și apărare
- bogată în povestiri reale
- ușor de citit
- conține formalisme, dar insistă pe aspecte practice

Bruce Schneier



http://en.wikipedia.org/wiki/File:Bruce_Schneier_1.jpg

- autorul mai multor cărți de securitate
- algoritmi de criptografie
- Bruce Schneier on security (blog) (`http://www.schneier.com`)
- Bruce Schneier Facts

RSA

- numele de la fondatorii: Ron Rivest, Adi Shamir, Led Adleman
- inființată în 1982
- algoritmul de criptare cu chei publice RSA
- token-uri de autentificare (RSA SecurID security tokens)
- RSA Factoring Challenge

AES

- *Advanced Encryption Standard*
- adoptat de guvernul US ca standard de criptare în noiembrie 2001
- inițial denumit Rijndael după numele unuia dintre inventatori
- înlocuiește algoritmul DES (Data Encryption Standard) din 1977
- procesul de alegere a avut loc între 1997 și 2000 – destinat comunității criptografice
- inițial aleși 15 algoritmi, apoi 5 finaliști, apoi doar 1 (Rijndael)

Cuvinte cheie

- securitate
- privilegii
- principii de securitate
- agenți, obiecte
- `umask`
- autentificare
- autorizare
- controlul accesului
- `root`
- `sudo`
- parole
- *password cracking*
- *passphrase*
- `/etc/passwd`
- `/etc/shadow`
- criptografie
- criptare, decriptare
- *plain text*, *ciphertext*
- chei simetrice
- chei asimetrice
- semnătură digitală
- semnare, verificare

Resurse utile

- http://www.unixtools.com/security.html
- http://insecure.org/
- http://www.linuxsecurity.com/
- http://www.schneierfacts.com/